I clicked a phishing link: what to do now

Article KB0010082 | Owner: Security Operations | Subcategory: Phishing report | Applies to: Windows 11 23H2/24H2 laptops (Dell Latitude 5440/7440, Lenovo ThinkPad T14/X1 Carbon, HP EliteBook 840), macOS 14/15 MacBook Pro/Air, All Acme Global employees using Microsoft 365 (Outlook, Teams, OneDrive)

Summary

If you suspect you have clicked a phishing link, act quickly to protect your account and Acme Global's data. This article guides you through immediate self-help steps, how to report the incident, and what the Service Desk and Security Operations teams will do to investigate and remediate the threat.

Symptoms

- You opened an email that appeared to be an invoice or a request for your password and clicked a link inside it.
- After clicking, you were taken to a login page that looked like Acme's sign-in screen but the URL was unfamiliar or misspelled.
- You may have entered your username and/or password on that page.
- You notice unexpected pop-ups, prompts to install software, or a download started automatically.

Common causes

- The email was a phishing message designed to harvest credentials or deliver malware.
- The link pointed to a spoofed website that mimics Acme's legitimate sign-in portal.
- If credentials were entered, attackers could attempt to sign in to your Microsoft Entra ID account.
- If the site hosted a malicious file, executing it could compromise your device.

Immediate Actions (Self-Help)

Do not panic. The goal is to limit any potential exposure while you gather information for the Security Operations team. Follow the steps below as soon as you realize you may have interacted with a phishing link.

1. Close the browser tab or window that opened after clicking the link. If you are unsure which tab, close all browsers and reopen a clean session.
2. Do not enter any further information on the suspicious site. If you already typed your password, note that you will need to change it.
3. Lock your workstation (Windows?+?L or Control-Command-Q on Mac) to prevent anyone else from using your session while you work.
4. Open the Outlook client or Outlook on the web and locate the original phishing email. Use the built-in 'Report' button (the shield icon) to send the message to Microsoft and to Acme's Security Operations mailbox. If you cannot find the button, forward the email as an attachment to phish@acme.example.
5. Navigate to the self-service password reset portal at https://passwordreset.acme.example and reset your Acme password. Choose a new password that meets the 14-character minimum, has not been used in the last 10 passwords, and is unique to Acme.
6. After resetting your password, go to https://myaccount.microsoft.com/security and review recent sign-in activity. Look for any unfamiliar locations, devices, or applications and select 'Sign out everywhere' if anything looks suspicious.

Report the Incident to Security Operations

Even after you have taken personal precautions, the Security Operations team needs to know about the attempt so they can block the sender, purge malicious messages from all mailboxes, and check for any broader impact.

1. If you used the Outlook 'Report' button, the email is already routed to the Security Operations mailbox (secops@acme.example). Confirm you see a confirmation message.
2. If you forwarded the email manually, include the full headers and note in the body that you clicked a link and possibly entered credentials.
3. Call the IT Service Desk at extension 4357 (HELP) or open a ticket in the self-service portal https://it.acme.example. Select the category 'Security / Phishing report' and provide: the time you clicked the link, the URL you were taken to (if you copied it), and whether you entered any credentials.
4. Keep the ticket open until you receive confirmation from Security Operations that the sender has been blocked and

the message removed from all mailboxes.

Password Reset and Session Revocation

Changing your password alone does not guarantee that an attacker who already captured your credentials is locked out. You must also revoke any active sessions or tokens that may have been issued during the compromise.

1. After resetting your password at https://passwordreset.acme.example, go to the Microsoft account security page (https://myaccount.microsoft.com/security).
2. Under 'Advanced security options', select 'Sign out everywhere'. This forces all active sessions and refresh tokens to be invalidated.
3. If you use Microsoft Authenticator for MFA, approve the push notification that appears when you sign back in to confirm your identity.
4. Optional: If you suspect malware was downloaded, run a quick scan with Microsoft Defender for Endpoint (open the Defender Security Center and choose 'Quick scan').

Checking Account Activity and Device Health

Verify that no unauthorized access occurred and that your device remains clean. This step helps you and the Service Desk confirm that the incident is contained.

1. In the Microsoft account security page, review the 'Recent activity' list for any sign-ins from unknown IP addresses or devices. Note the timestamp, location, and application used.
2. If you see any activity that you did not initiate, select 'Secure account' and follow the prompts to reset the password again (you already did) and to review connected apps.
3. On Windows, open Settings -> Privacy & security -> Windows Security -> Virus & threat protection -> Quick scan. On Mac, open Microsoft Defender for Endpoint from the menu bar and run a scan.
4. If Defender detects any threats, follow the quarantine instructions and inform the Service Desk so they can escalate to Desktop Support if needed.

Service-Desk Agent Procedure

When a user reports a possible phishing click, the Service Desk follows a structured workflow to verify the claim, secure the account, and hand off to Security Operations for deeper investigation.

1. Greet the user and confirm they have clicked a link in a suspicious email. Ask for the approximate time, the subject line of the email, and whether they entered any credentials.
2. Create a ticket in the Service Desk portal under Category: Security / Phishing report, Sub-category: User clicked link. Set initial priority to P2 (High) unless the user reports actual data loss, in which case raise to P1.
3. Advise the user to perform the self-help steps outlined in the 'Immediate Actions' section if they have not already done so.
4. If the user has not yet reported the email via Outlook's 'Report' button, guide them to do so or forward the email as an attachment to phish@acme.example.
5. Reset the user's password via the self-service portal or, if required, have the Identity & Access Management team issue a Temporary Access Pass and force a password change at next logon.
6. Revoke all sessions: instruct the user to sign out everywhere via the Microsoft account security page, or, if the user cannot perform this, use Azure AD PowerShell to revoke refresh tokens for the user's object ID.
7. Check the user's recent sign-in logs in Azure AD sign-ins blade for any anomalous entries; record IP addresses, locations, and applications.
8. If any suspicious sign-ins are found, escalate immediately to Security Operations (SecOps) with the ticket ID, user name, timestamp, and sign-in details.
9. If no suspicious activity is detected, close the ticket after confirming the sender has been blocked and the phishing message purged from all mailboxes (SecOps will provide confirmation).
10. Document all actions taken in the ticket resolution notes, including password reset timestamp, session revocation method, and any Defender scan results.

Verification and Closure

After the Service Desk and Security Operations have completed their steps, final verification ensures the user can

resume work safely and that the threat is fully mitigated.

1. Ask the user to sign back in to Outlook, Teams, and OneDrive to confirm the new password works and MFA prompts as expected.
2. Verify that the user can access their usual resources without encountering access-denied errors.
3. Request confirmation from Security Operations that the originating sender address has been added to the block list and that the phishing email has been removed from all mailboxes (including online archive and any backup copies).
4. If the user reported any malware symptoms, ensure Desktop Support has completed any required remediation and that the device is reporting clean in Microsoft Defender for Endpoint.
5. Close the ticket with a resolution summary: 'Phishing link clicked - password reset, sessions revoked, sender blocked, no Indicators of Compromise found.' Provide the user with the KB article link for future reference.

When to escalate

Escalate to Security Operations (SecOps) immediately if any of the following are observed: successful sign-in from an unfamiliar location or device after the click, presence of malware detected by Defender for Endpoint, or the user reports entering credentials on the phishing site. When escalating, include the ticket number, user name and employee ID, timestamp of the click, the URL visited (if known), whether credentials were entered, and any relevant Azure AD sign-in logs or Defender alerts. SecOps will investigate further, block the sender, purge the message, and advise on any additional containment measures.

Keywords: phishing, clicked link, fake invoice, password request, report email, Outlook report button, password reset, session revocation, sign-in review, Defender scan, Security Operations, SecOps, Temporary Access Pass, MFA, Microsoft Authenticator, self-service password reset, IT Help desk, extension 4357, phish@acme.example